

Enterprise Guardrails & Policy Engine

Fail-Closed Security Posture, Allow/Deny Glob Rules & Controlled Autonomy

Deterministic Safety: The Governance Policy Engine

Deploying autonomous agents in corporate environments demands strict, auditable guardrails. In `crates/governance`, Fathom implements a **fail-closed policy engine** where every tool call is authorized against declarative security rules prior to execution.

1. DECLARATIVE ALLOW / DENY GLOB RULES

- **Allow Search:** `allow: tool="web_search", target="*"`
- **Restrict Browser:** `allow: tool="browser.*", target="https://*.linkedin.com/*"`
- **Deny Admin Access:** `deny: tool="browser.type", target="*/admin/*"`
- **Deny Destructive Shell:** `deny: tool="shell", target="rm -rf *"`

2. STRICT FAIL-CLOSED SECURITY STANCE

- **Deny Wins:** If an action matches both allow and deny, **deny always takes absolute precedence**.
- **Unmatched Fails Closed:** If an action does not match an allow rule, it is rejected by default.
- **Operator Claim Gating:** Administrative actions require verified operator claims in HTTP headers.

Human Approval Side-Effect Registry

Configurable critical tools (e.g. `save_contacts`, `CRM push`, `git_push`) can be placed in the `approval_tools` list, ensuring that data never leaves the research sandbox without human sign-off.

Enterprise Compliance: Set exact operational boundaries for every virtual employee, preventing accidental data egress or unsanctioned system modifications.